

问

- 我们是一家中高端女装零售代理公司，只做线下门店，年销售额是几个亿左右，我们要做一个公司的网安方案，以下是我们现有的配置：



本地服务器

财务金蝶服务器，存储做账数据（每周备份到备份服务器）
域控服务器（每个人都有一个账户密码，），公司共享文件存储（人力花名册，面试资料等等）
副域控服务器（和域控服务器同步）
备份服务器（每天自动备份域控数据，每周备份财务数据）

天智 BI 服务器，用于做运营 BI 数据
加密服务器，总部和门店的所有主机都安装了一个加密程序

防火墙（深信服，没续费，病毒库是几年前的）
监控
路由器

阿里云

财务金蝶云服务器，存储做账数据（每天自动做快照）

腾讯云

驿氪CRM 数据库（做会员的）

电信机房

ERP 伯骏（做数据的）
防火墙（深信服，没续费，病毒库是几年前的）

答

这是一个非常典型的**中型零售企业混合云架构**。年销售额几个亿的规模，意味着你们已经成为了黑客（特别是勒索病毒）眼中的“肥羊”，但目前的防御体系却存在致命的短板。

基于你“自底向上”和“探究原理”的偏好，我将从**网络安全防御的演进历史**讲起，分析你们现有的风险，并给出一套分阶段的整改方案。

第一部分：核心风险评估（现状分析）

在安全界，有一个经典的概念叫**“木桶效应”**。你们的安全水平不取决于阿里云做了多少快照，而取决于那个**“没续费的深信服防火墙”**。

1. “裸奔”的边界（最致命）：

- 现状：** 防火墙没续费，病毒库停留在几年前。
- 原理：** 传统的防火墙依赖“特征库”（Signature-based detection）。它像一个拿着通缉令的门卫，只认识几年前的坏人。现在的勒索病毒（如 LockBit、Conti 的变种）每天都在变异，对于过期的防火墙来说，它们就是“正常流量”。
- 后果：** 勒索病毒一旦进入内网，会迅速加密金蝶财务数据和共享文件。**这是你们面临的最大灭顶之灾。**

2. 脆弱的内网信任：

- 现状：** 域控服务器管理账户，但看似缺乏VLAN隔离。

- **风险：** 如果某个门店的收银机（POS）或总部某员工中了钓鱼邮件，黑客可以通过“横向移动”（Lateral Movement）攻击域控，进而控制所有服务器。
3. **云端配置陷阱：**
- **现状：** 阿里云/腾讯云/电信机房混合部署。
 - **风险：** 很多企业认为上了云就安全。但云厂商只负责“云的安全”（基础设施），不负责“云上的安全”（你的配置）。如果你们的 ERP 或 CRM 数据库端口（如 SQL Server 的 1433 或 MySQL 的 3306）对公网开放，且密码强度不够，极易被暴力破解。
-

第二部分：整改方案（自底向上构建防御体系）

我们将遵循**纵深防御（Defense in Depth）**的原则，从网络层到数据层层层设防。

1. 网络层（Network Layer）：重建护城河

这是防御的第一道防线。在历史上，网络安全始于“边界防御”（Castle-and-Moat model）。虽然现在流行“零信任”，但对于你们目前的阶段，修好“城墙”是第一要务。

- **[紧急] 恢复防火墙能力（总部 & 电信机房）：**
 - **动作：** 立即续费深信服的授权，开启**IPS（入侵防御系统）**和**僵尸网络检测**功能。
 - **进阶：** 如果设备太老（超过5年），建议更换为**下一代防火墙（NGFW）**。NGFW 不仅看端口，还能识别应用层流量（例如：它能看出这是正常的网页访问，还是伪装成网页访问的病毒通讯）。
- **网络隔离（VLAN划分）：**
 - **原理：** 就像船舱设计隔水舱一样，一个舱漏水不应导致整艘船沉没。
 - **动作：** 在核心交换机上划分 VLAN：
 - **VLAN 10：** 财务部（只允许访问金蝶服务器，禁止访问互联网或只允许白名单）。
 - **VLAN 20：** 普通办公（访问共享文件）。
 - **VLAN 30：** 访客 Wi-Fi（完全隔离，不能访问内网任何服务器）。
 - **VLAN 40：** 服务器区（仅允许特定端口访问）。

2. 主机与系统层（Host Layer）：终端加固

- **域控加固（AD Security）：**
 - **历史背景：** Active Directory (AD) 是 Windows 网络的核心。历史上无数的大型入侵（如 2020 年 SolarWinds 事件）都是通过攻破 AD 拿到“上帝权限”。
 - **动作：**
 - 域管理员账户**必须**开启复杂密码，并且**绝对禁止**在普通员工电脑上登录（防止哈希抓取攻击）。
 - 开启账户锁定策略（输错5次密码锁定账户）。
- **加密与杀毒：**
 - **现状：** 你们有“加密服务器”。通常这类软件（如IP-guard, 亿赛通）侧重防内鬼泄密（DLP），而非防病毒。
 - **动作：** 需要部署**企业级 EDR（端点检测与响应）**软件（如深信服 EDR、卡巴斯基企业版、火绒企业版）。EDR 比传统杀毒软件更先进，它能记录行为日志，发现“虽然没见过这个病毒，但这个程序在疯狂加密文件”的异常行为。

3. 数据层（Data Layer）：最后的底牌

数据备份是勒索病毒攻击后的唯一后悔药。

- **[关键] 实施 3-2-1 备份原则：**
 - **原理：** 3份数据副本，2种不同介质，1份**异地离线**备份。
 - **漏洞修正：** 你们目前的备份都在“服务器”上。如果勒索病毒攻破了域控，它通常会扫描网络，把备份服务器一起加密了。
 - **动作：**

- **离线备份 (Air Gap) :** 买一台磁带机或者移动硬盘, 或者使用专门的云备份服务 (对象存储)。每周备份完财务数据后, 物理断开网络连接。
- **不可变备份 (Immutable Backup) :** 阿里云/腾讯云通常提供“对象存储锁定”功能, 设置数据在N天内由于任何权限都无法删除或修改。

4. 云端安全 (Cloud Security) : 收敛暴露面

- **安全组 (Security Groups) 清洗:**
 - 检查阿里云、腾讯云和电信机房的防火墙策略。
 - **原则:** 默认拒绝所有 (Deny All) 。只开放必须的端口。
 - **特例:** 金蝶云、CRM 数据库尽量 **不要** 直接暴露公网 IP。
 - **建议:** 搭建 **VPN (如 SSL VPN)** 或 **SD-WAN**。门店和总部通过 VPN 隧道访问云端数据库, 而不是通过公网直接连数据库端口。

第三部分: 推荐实施路线图

鉴于成本和紧迫性, 建议分三步走:

第一阶段: 止血 (立刻执行, 1周内)

1. **续费防火墙:** 恢复深信服的病毒库更新和 IPS 功能。
2. **云端体检:** 登录阿里/腾讯云控制台, 查看安全组规则, 关闭所有不必要的端口 (特别是 135, 139, 445, 3389 端口) 。
3. **离线备份:** 人工手动拷贝一份最新的财务和会员数据到移动硬盘, 并锁入保险柜。

第二阶段: 加固 (1-2个月)

1. **部署企业级杀毒/EDR:** 确保每台电脑 (包括门店收银机) 都有最新的防护。
2. **网络隔离:** 实施 VLAN 划分, 把财务部独立出来。
3. **VPN组网:** 解决电信机房和云端数据库直连公网的高危问题。

第三阶段: 完善 (3-6个月)

1. **行为审计:** 利用“天智 BI”或上网行为管理设备, 分析员工是否存在违规外联行为。
2. **灾难恢复演练 (DRP) :** 尝试从备份中恢复一次数据, 确保备份文件是可用的 (很多公司备份了几年, 真出事发现备份文件是坏的) 。